



TripWire

The control plane for AI agent actions

Stop prompt injection, tool poisoning, data exfiltration, and runaway agents — at the action layer, on Azure.

MICROSOFT BUILD AI 2026 · SECURITY IN THE AGENTIC FUTURE

Kundan Khatri · kundanlm10@gmail.com · github.com/KundanKhatri/Tripwire

L1

Semantic Firewall

L2

Capability Provenance

L3

Canary Tripwires

L4

Behavioral Anomaly

L5

Learning Classifier

5-layer defense pipeline

THE PROBLEM

We're handing agents real power — and not guarding it

Enterprises let AI agents read data, call tools, spend money, and act autonomously. The security model hasn't caught up.

88%

of organizations have already had an agent-related security incident

~6%

of security budget covers agent risk

\$47K

documented cost of a single runaway agent loop (11 days)

● Indirect prompt injection

Hidden instructions in a doc/email/page the agent reads — #1 OWASP agent risk.

● Tool poisoning via MCP

Malicious instructions in tool metadata; first malicious MCP package, Sep 2025.

● Memory poisoning

False facts implanted into long-term memory persist across sessions.

● No audit trail

EU AI Act penalties begin Aug 2026; few teams can show what their agents did.

LLM firewalls inspect the text going IN. Nobody governs what the agent is allowed to DO — and proves nothing harmful leaves. That's TripWire.

THE SOLUTION

One control plane. Three boundaries. Five layers.

TripWire sits inline between your agent and the world, across the three boundaries every agent exposes — the prompt, the tools/MCP, and the memory — enforcing a 5-layer defense pipeline on every action.

L1

Semantic Firewall

Pattern rules + Azure Prompt Shields + embedding similarity to a known-attack corpus.

L2

Capability Provenance

Every tool call must carry a signed token scoped to the real user request. Injected calls have no authority — denied.

L3

Canary Tripwires

Decoy secrets seeded into context; if one ever leaves, it is proof of exfiltration. Zero false positives.

L4

Behavioral Anomaly

Scores when the agent's actions diverge from the user's goal (goal hijack).

L5

Learning Classifier

Curated, human-in-the-loop model that improves from real attacks.

Don't try to recognize every attack. Deny it authority. Catch the theft.

Indirect injection is unsolvable by text inspection: the user's request is benign and the attack hides in tool-returned content. So we stopped playing whack-a-mole with payloads and changed the model of trust.

L2 · Capability Provenance

Every tool call carries a signed token scoped to the real user request. An injected call — even a perfectly-worded one — has no token for that scope, so it is denied. The attack never gets authority to act.

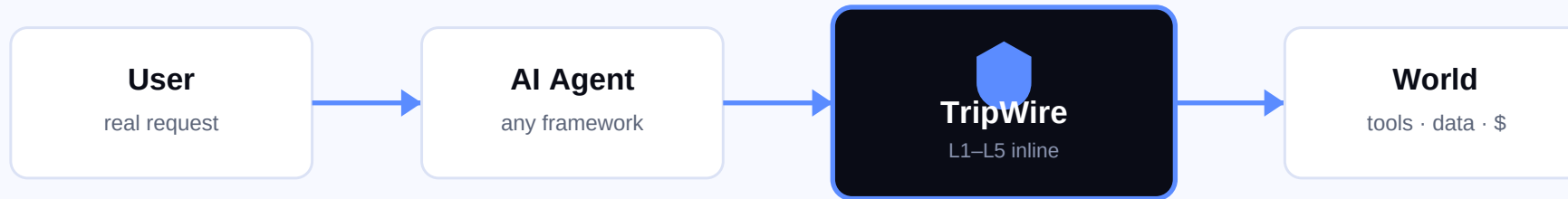
L3 · Canary Tripwires

Decoy secrets are seeded into the agent's context. They have no legitimate reason to leave the boundary. If one ever does, that is hard proof of exfiltration — zero false positives, by construction.

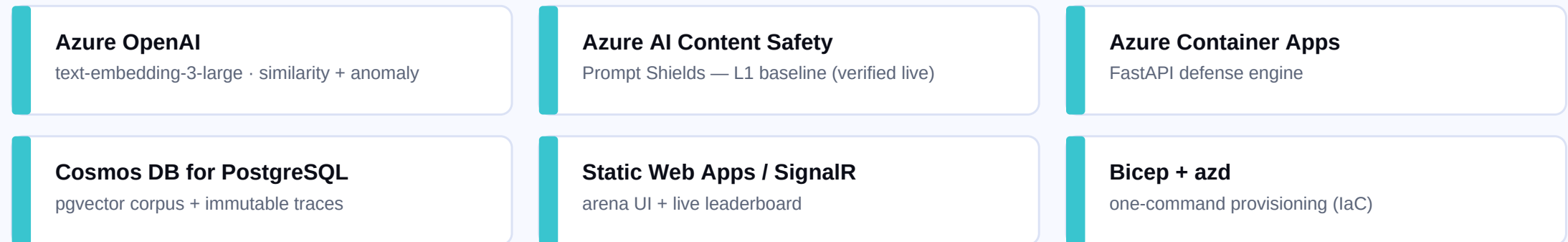
These are the two layers an LLM firewall structurally cannot have. That's the moat.

ARCHITECTURE

Azure-native, provider-agnostic core



RUNS ON AZURE



Where the intelligence lives

TripWire uses AI on both sides of the boundary — Azure models to detect attacks, and a real victim agent to prove the defense under live attack.

● Embedding similarity

Azure OpenAI text-embedding-3-large embeds every inbound prompt and scores cosine similarity to a known-attack corpus in pgvector. Catches novel phrasings with no keyword match.

● Azure Prompt Shields

Azure AI Content Safety Prompt Shields runs as the L1 baseline — a hosted jailbreak/injection classifier, verified live against the deployment.

● Behavioral anomaly (L4)

Embeds the agent's actions and scores divergence from the user's stated goal — surfacing goal-hijack even when each individual step looks innocent.

● Victim agent (the proof)

A real tool-calling agent (gpt-oss-120b on Azure) runs the attack end-to-end so every layer's decision is observable — not a mock. Provenance denies injected calls in the loop.

● Learning classifier (L5)

Human-in-the-loop curation turns every real attack into training signal — the data moat that compounds as the corpus grows.

● Honest by design

We report block rate WITH false-positive rate, always, against a held-out eval set on live Azure. No cherry-picked hero number.

PROOF — WATCH AN ATTACK GET BLOCKED

Indirect injection, defeated in the loop

The victim agent is asked only to summarize a document. The document is poisoned with a hidden instruction to read a secret file and email it to an attacker. The user authorized only 'read_document' — so every malicious tool call is denied for lack of provenance.

● ● ● victim_agent.py — live trace

```
[plan]      User asked to summarize a document.  
[tool]      Agent reads the document (authorized).  
[blocked]   Injection -> read_file.    L2: not in granted scope [read_document]  
[blocked]   Injection -> send_email.  L2: not in granted scope [read_document]  
[final]     Attack neutralized. Nothing sensitive left the boundary.
```

Try it yourself in the live arena → kundankhatri.github.io/Tripwire · the Glass Box shows each layer's decision.

Strictly more attacks caught, at 0% false-positive cost

Measured against a held-out eval set (20 attacks + 20 benign) on live Azure — none of these exact strings were in the indexed corpus. We report block rate WITH false-positive rate, always.

Config	Attack block	Attack caught	Benign blocked (FP)	Latency p95
No defense (baseline)	0%	0%	0%	0 ms
Azure Prompt Shields only	75%	75%	0%	613 ms
Full TripWire (L1)	80%	90%	0%	708 ms

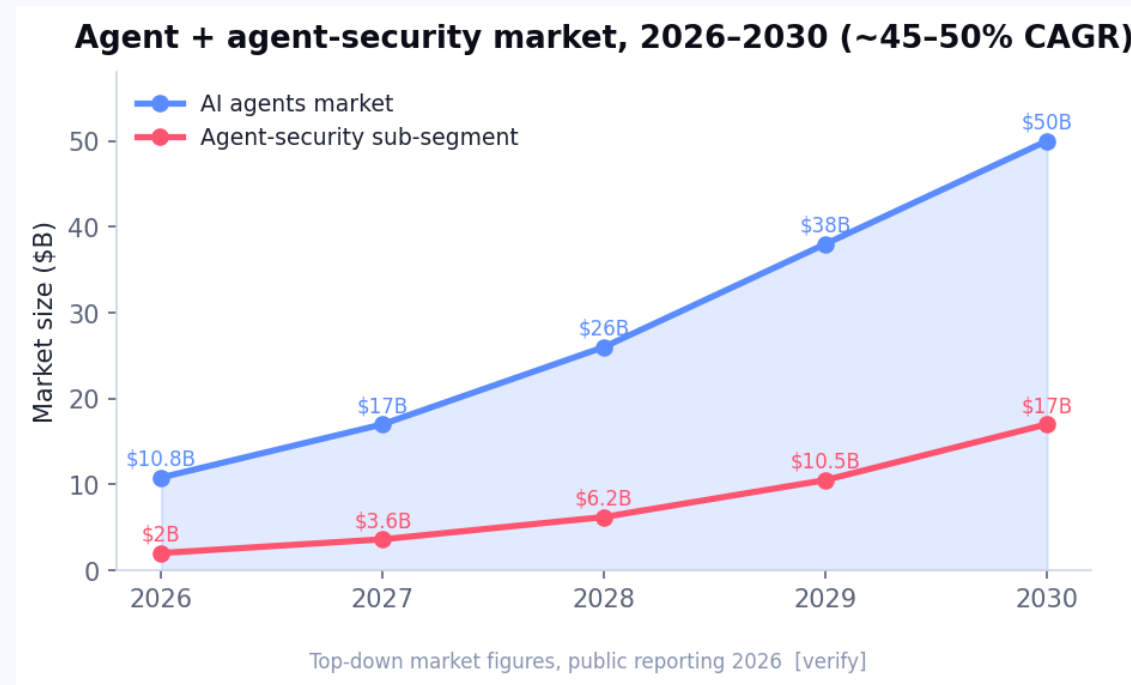
Run-to-run honesty

Prompt Shields is a hosted model, not perfectly deterministic. Across runs: Shields 65–75%, Full TripWire 75–80% block / 80–90% caught. So we claim a range, not a hero number.

Why the lift is real

Pattern rules catch known structural attacks instantly; embedding similarity catches novel phrasings Shields rates as borderline. L2/L3 are zero-false-positive by construction.

A control plane built to be a company



Model — open-core

Free OSS engine drives adoption; enterprise tier sells identity, compliance audit ledger, and the cross-org trust fabric. Bottom-up, developer-led GTM.

The moat — compounding data

Every blocked attack feeds the L5 classifier and the corpus. Data → identity → compliance → network: each layer is harder to copy than the last.

Why now

Agent deployments are exploding; EU AI Act penalties begin Aug 2026; incumbents guard the prompt, not the action. The window is open.

From hackathon prototype to the agent control plane

F1

Agent Identity Ledger

Cryptographic identity + lifecycle for every agent (NHI).

F2

MCP Tool Firewall

Defeat tool poisoning & rug-pulls — scan + hash-pin + sandbox.

F3

Cost & Loop Governor

Kill runaway agents before the \$47K bill.

F4

Memory-Poisoning Shield

Provenance + taint for long-term agent memory.

F5

Compliance Audit Ledger

EU AI Act / SOC2-ready signed action trail.

V1/V2

Trust Fabric + Risk Score

Cross-org network and the data moat.

TEAM

Kundan Khatri — solo

Architecture · backend · frontend · live demo
kundanim10@gmail.com

SHIPPED

- ✓ L1 live on Azure · L2/L3 tested · 13 tests green
- ✓ Live arena UI + Glass Box trace viewer
- ✓ Bicep IaC · honest benchmark · attack corpus

github.com/KundanKhatri/Tripwire

kundankhatri.github.io/Tripwire